

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE FUSIONNÉ
Méthode MUSA - Cas GIDOCEP / SOLTEC

PLAN D'AUDIT

Mission MUSA-GIDOCEP-2026-SOLTEC

Référence mission	MUSA-GIDOCEP-2026-SOLTEC
Entité auditée	SOLTEC, application GIDOCEP
Objet de la mission	Audit de sécurité applicative fusionné de GIDOCEP (méthode MUSA)
Type d'audit	Audit de conformité et d'efficacité, fusionnant audit applicatif et audit de sécurité
Commanditaire	Direction Générale SOLTEC (ou représentant mandaté)
Chef de mission	TOMI OLAMA Gabrielle Solange, étudiante-auditrice, ENSPY
Période terrain	
Version	V1.0 , Finale (plan exécuté ; mission terrain achevée)
Classification	CONFIDENTIEL, Usage exclusif mission de fin d'études

△ Règle absolue : le présent plan d'audit marque la fin de la phase de planification. Il doit être validé formellement (superviseur académique + encadreur professionnel) avant tout démarrage des travaux de terrain.

1. Contexte et objectifs de la mission

1.1 Contexte

SOLTEC, PME camerounaise éditrice de GIDOCEP, ne peut supporter le coût cumulé d'un audit applicatif et d'un audit de sécurité distincts sur un même cycle budgétaire. La présente mission applique MUSA, méthode fusionnant ces deux audits en une seule grille d'évaluation, au cas réel de GIDOCEP, dans le cadre d'un mémoire de fin d'études ENSPY.

1.2 Objectifs de la mission

Objectif principal : fournir une évaluation fusionnée, documentée et reproductible du niveau de maîtrise applicative et sécuritaire de GIDOCEP, validant MUSA comme alternative viable aux audits séparés pour les PME.

Réf.	Domaine	Objectif spécifique
OS-A	Authentification & Contrôle d'accès	Évaluer la robustesse technique de l'authentification et la gouvernance des droits d'accès (revue périodique, comptes inactifs).
OS-B	Journalisation & Traçabilité	Vérifier l'existence et l'exploitation effective des logs applicatifs et la détection d'intrusion.
OS-C	Sécurité des données	Évaluer le chiffrement, le contrôle des entrées/sorties et la sécurité des interfaces inter-applicatives.
OS-D	Continuité & Sauvegarde	Vérifier les sauvegardes, leur test de restauration réel, et l'existence d'un PRA/PCA formalisé.
OS-E	Gouvernance & Organisation	Vérifier la désignation d'un propriétaire applicatif, la politique de patching et la protection contre les injections SQL.
OS-F	Transversal (méthodologique)	Mesurer par domaine l'écart entre réponse technique et réponse organisationnelle via l'entropie de Shannon, afin d'objectiver les zones de conformité en trompe-l'œil.

2. Référentiels retenus

Type	Référentiel	Utilisation dans la mission
Interne	Méthode MUSA (Méthode Unifiée d'Audit de Sécurité Applicative)	Référentiel fusionné de 21 assertions (15 initiales + 6 assertions « G » ajoutées lors du cadrage) et grille O/N/PAS ; outil principal de collecte et de scoring

Légal	Loi n°2010/012 du 21 décembre 20 Cybersécurité et cybercriminalité au Cameroun	Conformité légale des SI ; obligations de notification ANTIC
Légal	Décret n°2013/0399/PM Organisation de l'ANTIC	Obligations de déclaration et de conformité cybersécurité
Normatif	ISO/IEC 27001:2022 et ISO/IEC 27002:2022	Évaluation des contrôles de sécurité logique et bonnes pratiques
Normatif	OWASP ASVS v4.0.3	Critères techniques de sécurité applicative (référentiel privilégié pour le volet 'applicatif' fusionné)
Normatif	IIA Normes 2024	Cadre déontologique et méthodologique de la mission
Normatif	ISO 19011:2018	Cadre de réalisation et gestion du programme d'audit

3. Évaluation a priori du système de contrôle interne

ÉVALUATION A PRIORI : FAIBLE

Justification : l'audit externe ST DIGITAL (2026), commandité par l'État camerounais, a déjà conclu à une absence de structure de pilotage et de coordination de GIDOCEP, entraînant un usage différencié d'un établissement à l'autre. La collecte documentaire préalable (Phase 0) a confirmé l'absence de schéma d'architecture, de matrice des droits d'accès et de procédure de gestion des accès. Cette évaluation a justifié une approche renforcée sur les domaines A (accès), C (données) et D (continuité), où l'écart technique/organisationnel s'est effectivement révélé le plus marqué (résultat confirmé a posteriori : 12 assertions sur 21 Non Conformes, maturité globale 29,2 %).

4. Cartographie préliminaire des risques

Risques cotés selon Criticité = Probabilité × Impact, sur la base des critères DICT (Disponibilité, Intégrité, Confidentialité, Traçabilité). À affiner en Phase 1.

Réf.	Risque préliminaire	Domaine MUSA	Prob.	Impact	Criticité	Assertions liées
R01	Absence de séparation stricte des rôles applicatifs ; cumul de privilèges non contrôlé → Résultat terrain : CONFIRMÉ, A2 Non Conforme	A	M	H	ÉLEVÉ	A2, A3
R02	Journalisation applicative non exploitée en pratique malgré son existence technique → Résultat terrain : CONFIRMÉ, B1 Non Conforme (criticité 9/9)	B	M	H	ÉLEVÉ	B1, B2
R03	Absence de politique formalisée de classification et de chiffrage des documents financiers → Résultat terrain : CONFIRMÉ, C1 Non Conforme (criticité 9/9) : HTTP non chiffré	C	M	H	ÉLEVÉ	C1
R04	Sauvegardes existantes mais jamais testées en restauration réelle → Résultat terrain : CONFIRMÉ - D1 Non Conforme (criticité 9/9) : sauvegardes non testées, PRA absent	D	M	H	ÉLEVÉ	D1
R05	Absence de propriétaire applicatif formellement désigné pour GIDOCEP → Résultat terrain : CONFIRMÉ, E1 Non Conforme (criticité 5/9) : RSSI informel, non formalisé	E	M	M	MOYEN	E1
R06	Écart entre maturité technique déclarée et maturité organisationnelle réelle (zone grise) → Résultat terrain : CONFIRMÉ — 12/21 assertions Non Conformes, 9/21 en zone grise ; maturité globale 29,2 % (Niveau 1)	Transversal	M	M	MOYEN	Toutes
R07	Documents comptables sans matrice de droits, classification ni versionnement formalisés (points G1, G2, G4) → Résultat terrain : NON TESTÉ (zone grise, hors capacité de vérification de la mission, accès limité)	C	F	M	FAIBLE	G1, G2, G4

R08	Absence de politique d'archivage légal et de destruction sécurisée des documents comptables (points G5, G6) → Résultat terrain : NON TESTÉ (zone grise)	D, E	F	M	FAIBLE	G5, G6
-----	--	------	---	---	--------	--------

5. Méthodologie de la mission

Audit de conformité et d'efficacité conduit selon ISO 19011:2018, structuré par la décomposition hiérarchique MUSA (Domaine → Assertion fusionnée → Critère technique/organisationnel → Élément requis → Question d'évaluation → Réponse OK/KO/NSP par sous-volet → Réponse fusionnée O/N/PAS). L'Outil MUSA déploie cette grille comme instrument principal de collecte et de scoring ; l'entropie de Shannon H par domaine détecte les zones d'incertitude nécessitant un approfondissement ($H \geq 1,0$ = investigation complémentaire obligatoire).

- Revue documentaire : spécifications, configurations, politiques SOLTEC
- Entretiens fusionnés structurés (cf. Outil 5. Guide d'entretien)
- Tests et vérifications techniques : droits d'accès, chiffrement, sauvegarde, journalisation
- Analyse comparative technique vs organisationnelle et calcul d'entropie par domaine

6. Programme de travail par domaine (papiers de travail attendus)

Chaque domaine fait l'objet d'un papier de travail (PT) reliant : assertion(s) fusionnée(s) → question(s) d'entretien → preuve collectée auprès de l'AUDITÉ (SOLTEC) → réponse fusionnée O/N/PAS → conclusion. Le PT documente systématiquement la réponse de l'audité et la preuve associée — jamais une appréciation de la performance de l'auditeur.

- PT-A : Authentification & Contrôle d'accès (assertions A1-A3)
- PT-B : Journalisation & Traçabilité (assertions B1-B2)
- PT-C : Sécurité des données (assertions C1-C4)
- PT-D : Continuité & Sauvegarde (assertions D1-D2)
- PT-E Gouvernance & Organisation (assertions E1-E4)

7. Calendrier prévisionnel

Phase	Activités principales	Durée indicative
Phase 0. Préparation	Collecte des documents T01-T05 et G01-G13 (cf. Outil 3), prise de contact SOLTEC	5 j (avant le 17/06/2026)
Phase 1. Planification	Analyse documentaire préliminaire, cotation des risques, finalisation du présent plan	fusionnée avec la Phase 0, close le 17/06/2026
Phase 2. Terrain	Entretiens fusionnés par domaine (A à E), tests techniques (droits, config, chiffrement, sauvegarde)	4 j (17 au 20/06/2026) — compressé par rapport au format standard MUSA (7-10 j) en raison des contraintes du mémoire
Phase 3. Analyse & rédaction	Calcul des réponses fusionnées O/N/PAS, entropie de Shannon par domaine, rédaction des constats	21/06 au 10/07/2026 (environ)
Procédure contradictoire	Présentation des constats provisoires à SOLTEC, recueil des réponses	10 jours ouverts ; aucune contestation formulée par SOLTEC
Phase 4. Rapport définitif	Intégration des réponses, finalisation du rapport et du mémoire	rapport transmis ; suivi post-audit sur jalons J+15 (28/07), M+1 (28/08), M+2 (28/09), M+3 (28/10/2026)

8. Composition de l'équipe

- TOMI OLAMA Gabrielle Solange Chef de mission / étudiante-auditrice — ENSPY
- M. Patrick MBOUL Encadreur professionnel / Expert métier SOLTEC
- M. TIOGNING Lauraine Superviseur académique ENSPY
- M. NJEI CHECK Référent institutionnel (Directeur du Département d'Audit de Sécurité de l'ANTIC)
- M. MINKA MI NGUIDJOI Thierry Emmanuel , Superviseur général (Chief Cybersecurity Officer)

9. Validation du document

Conformément à ISO 19011:2018, le présent plan fait l'objet d'une validation formelle par le superviseur académique et l'encadreur professionnel avant tout démarrage des travaux de terrain.

Signataires : TOMI OLAMA Gabrielle Solange (Chef de mission) / M. TIOGNING (Superviseur académique) / M. Patrick MBOUL (Encadreur professionnel SOLTEC) , plan validé, mission exécutée.

Méthode MUSA (Inspirée du chapitre 7 Cours d'Audit des Systèmes d'Informations | HN3-ENSPY | cours disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres>